COMPTIA SECURITY+ SY0-701 | DOMÍNIO 3 · ARQUITETURA DE SEGURANÇA (18%)

Security+ 3.1 · Other Infrastructure Concepts

Mestre CyberSec · **Aula 3.1 — Other Infrastructure Concepts** (14:24) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

> **Resumo Executivo da Aula:** VM (hypervisor virtualiza o hardware — isolamento forte); container (Docker — roda na kernel do host, leve, isolamento mais fraco por default); ICS/OT (Sistemas industriais: PLC controla a fábrica; SCADA monitora; MUITO patch-hard — ar gap, USB é o vetor, protocolos Modbus/DNP3).

💡 Highlights que a prova CompTIA cobra

- VM: isolamento STRONG (hypervisor). Container: mais leve, compartilha kernel
- ICS/OT (fábrica, usina): patch MUITO difícil — air gap, DMZ industrial
- IoT/devices: superfície GIGANTE e PATCH-fraco

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'isolated with strong boundary' = VM; 'shares kernel with host' = container
- 'sistema industrial isolado com protocolo especial' = ICS/OT

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 3.1 — Other Infrastructure Concepts)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Máquina Virtual (VM)

Sistema operacional convidado completo rodando sobre hardware abstraído fornecido pelo hypervisor, com forte isolamento entre o host e outras VMs. Cada VM possui seu próprio SO, kernel, memória e CPU/storage virtualizados.

⚠️ ***Armadilha CompTIA:*** *Cenário com 'strong isolation / strong boundary between environments' = resposta VM/hypervisor. Se a questão fala em consolidar servidores ou isolar apps inseguras com limite forte de separação, pense VM — não container.*

• Hypervisor (Tipo 1 / Tipo 2) (VMM)

Camada de software (Virtual Machine Monitor) que gerencia a abstração de hardware e aloca recursos às VMs. Tipo 1 (bare-metal) roda direto no hardware (VMware ESXi, Hyper-V); Tipo 2 roda sobre um SO hospedeiro (VirtualBox, Workstation).

⚠️ ***Armadilha CompTIA:*** *Type 1 = datacenter/data center, maior performance e segurança; Type 2 = desktop/laboratório. Também lembre: VM escaping (fuga de VM) é o risco de invasor pular da VM para o host — citar isso indica questão sobre risco de virtualização.*

• Container

Método leve de virtualização (ex.: Docker) em que aplicações empacotam código e dependências, mas COMPARTILHAM o kernel do SO hospedeiro em vez de rodar um SO convidado completo. Mais rápido e eficiente, porém com isolamento mais fraco que VMs por padrão.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'shares the host kernel', 'lightweight/fast deployment', 'packages application with dependencies' = Container. Se a pergunta pedir isolamento MAIS forte entre aplicações, a resposta é VM — container compartilha kernel e isolamento é mais fraco.*

• Sistemas de Controle Industrial / Tecnologia Operacional (ICS/OT)

Hardware e software que monitoram e controlam processos físicos industriais (fábricas, usinas, tratamento de água). OT prioriza disponibilidade e segurança física em vez de patches — sistemas rodam por décadas e não podem ser reiniciados ou atualizados facilmente.

⚠️ ***Armadilha CompTIA:*** *Cenário com 'sistema industrial, usina, fábrica, não pode receber patch por uptime' = ICS/OT. Defesas corretas: air gap, DMZ industrial, segmentação — NUNCA 'aplicar patch imediato' ou 'conectar à internet'.*

• Controle Supervisório e Aquisição de Dados (SCADA)

Tipo de ICS que fornece monitoramento e controle supervisório centralizado e em larga escala de equipamentos industriais distribuídos (ex.: dutos, rede elétrica), coletando dados e enviando comandos a PLCs/RTUs.

⚠️ ***Armadilha CompTIA:*** *SCADA = supervisão/monitoramento em larga escala e distribuído; PLC = controle local e direto do equipamento. Lembre do Stuxnet como exemplo clássico de ataque a SCADA/ICS via USB em rede com air gap.*

• Controlador Lógico Programável (CLP/PLC)

Computador embarcado robusto que controla diretamente máquinas e processos físicos no chão de fábrica (motores, válvulas, sensores), executando lógica em tempo real e comunicando-se com sistemas SCADA.

⚠️ ***Armadilha CompTIA:*** *Distinção clássica: PLC 'controla' (age sobre o equipamento), SCADA 'monitora/supervisiona'. Se a questão descreve o dispositivo que liga/desliga a máquina física na fábrica, a resposta é PLC.*

• Isolamento Físico de Rede (Air Gap)

Estratégia de isolamento físico em que uma rede sensível (tipicamente ICS/OT) NÃO possui conexão lógica ou física com outras redes ou a internet, protegendo contra ataques remotos.

⚠️ ***Armadilha CompTIA:*** *Principal defesa para ICS/OT na prova — mas cuidado: air gap NÃO impede ataque via mídia removível. Questões citando 'USB drive' em ambiente isolado = vetor clássico para furar o air gap (Stuxnet).*

• Modbus / DNP3

Protocolos legados de comunicação industrial usados entre dispositivos ICS (PLCs, SCADA). Projetados para confiabilidade, não segurança — não possuem autenticação e criptografia nativas, tornando o tráfego OT alvo privilegiado de ataques.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'protocolo especial/legado de sistema industrial sem criptografia ou autenticação' = Modbus/DNP3 → ambiente ICS/OT. Compensação correta: segmentação, DMZ industrial e monitoramento — não mexer no protocolo.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Redes Definidas por Software (SDN): Plano de Controle vs. Plano de Dados

🏠 **Analogia Intuitiva:** Imagine a malha ferroviária de um país: o Plano de Dados (Data Plane) são os trilhos de aço e as composições de vagões que carregam o peso do carvão (o hardware que encaminha os pacotes físicos de rede na velocidade da luz). O Plano de Controle (Control Plane) é a torre central de tráfego com os engenheiros de trânsito em telas de computador dizendo quais desvios e agulhas devem se abrir ou fechar. Antes do SDN, cada vagão precisava ter um guarda decidindo individualmente o caminho.

🔍 **Causa Raiz / Por que foi criado:** Configurar roteadores e switches individualmente via linha de comando manual (CLI) causava erros humanos graves e lentidão para ajustar rotas de segurança. O SDN centraliza as políticas de segurança e segmentação em um único software mestre.

🛡️ **Visão do Auditor de GRC:** Auditar controles de acesso rigorosos (RBAC e MFA) ao controlador SDN central; certificar que os canais de controle (ex: OpenFlow) usem TLS criptografado para evitar ataques on-path que sequestrem a topologia da rede.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'separates the control plane from the data forwarding plane to allow centralized and programmatic network management'. Resposta: Software-Defined Networking (SDN).

📌 SD-WAN (Software-Defined Wide Area Network)

🏠 **Analogia Intuitiva:** É como o aplicativo Waze instalado na frota de caminhões da empresa: o caminhão pode usar a rodovia pedagiada cara (link dedicado MPLS), a rodovia comum (banda larga residencial barata) ou até a balsa (link 4G/5G). O motorista não precisa escolher manualmente: o Waze monitora o trânsito a cada segundo e desvia automaticamente o tráfego de voz e vídeo pela estrada mais rápida e sem buracos.

🔍 **Causa Raiz / Por que foi criado:** Conexões MPLS tradicionais entre filiais são extremamente lentas para provisionar e absurdamente caras. O SD-WAN permite combinar conexões baratas de Internet comum com criptografia IPsec ponta a ponta e roteamento dinâmico baseado em qualidade de serviço.

🛡️ **Visão do Auditor de GRC:** Inspecionar conformidade da criptografia nos túneis sobre a Internet pública (AES-256); revisar políticas de 'Split Tunneling' e 'Direct Internet Access' nas filiais para evitar desvio de tráfego fora da inspeção do firewall central.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'dynamic multi-path routing across commodity broadband, MPLS, and cellular connections to optimize branch WAN performance securely'. Resposta: SD-WAN.

📌 Microsserviços e APIs: Portais de Comunicação Desacoplados

🏠 **Analogia Intuitiva:** Em um monolito tradicional, a empresa é uma sala única onde trabalham 100 pessoas conversando ao mesmo tempo: se um colaborador passar mal com gripe, todos se contagiam e o escritório fecha inteiro. Na arquitetura de Microsserviços, cada função é uma cabine independente e lacrada: uma só calcula frete, outra só processa cartão de crédito. Elas conversam entre si por portinholas seguras com garçons uniformizados chamados APIs (Application Programming Interfaces).

🔍 **Causa Raiz / Por que foi criado:** Sistemas monolíticos quebram por inteiro diante de qualquer falha pontual e são lentos para atualizar. Microsserviços garantem resiliência e independência, mas multiplicam exponencialmente a superfície de ataque de rede e dependem de autenticação contínua em APIs.

🛡️ **Visão do Auditor de GRC:** Auditar o inventário contínuo de endpoints de API para combater 'Shadow APIs' ou APIs zumbis esquecidas; exigir autenticação forte (OAuth 2.0 / mTLS) e rate limiting implementados no API Gateway.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'application architecture broken down into small, modular, independently scalable services communicating over HTTP/REST APIs'. Resposta: Microservices.

📌 Orquestração de Contêineres: Kubernetes e Gestão de Clusters

🏠 **Analogia Intuitiva:** Se um contêiner Docker é uma caixa de transporte padrão, o Kubernetes é o comandante do navio cargueiro e o operador do guindaste do porto. Ele sabe exatamente quantos contêineres cabem no convés, monitora se algum caiu no mar durante a tempestade para substituí-lo imediatamente por outro idêntico, e equilibra o peso da carga para o navio não tombar.

🔍 **Causa Raiz / Por que foi criado:** Gerenciar centenas ou milhares de contêineres manualmente é humanamente impossível. A orquestração automatiza o ciclo de vida, mas erros de configuração no painel mestre (Control Plane / Kube-API) ou contêineres rodando em modo privilegiado podem comprometer o nó físico inteiro.

🛡️ **Visão do Auditor de GRC:** Verificar se contêineres rodam com restrição de privilégios ('readOnlyRootFilesystem: true' e sem 'privileged: true'); auditar políticas de rede (Network Policies) para impedir que um contêiner comprometido varra os demais pods.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'automates the deployment, scaling, health monitoring, and lifecycle management of containerized applications across a cluster of nodes'. Resposta: Container Orchestration (Kubernetes).

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Separação lógica entre as decisões de roteamento (software central) e o envio físico de pacotes nos equipamentos	**SDN (Software-Defined Networking)**
Otimização dinâmica de tráfego de filiais combinando links de Internet comercial, fibra e conexões móveis	**SD-WAN**
Sistema composto por serviços independentes e modulares que conversam entre si via chamadas web estruturadas	**Microsserviços e APIs**
Plataforma que gerencia escalabilidade automática, reinício de falhas e implantação de contêineres em servidores	**Orquestração de Contêineres (Kubernetes)**
Camada que controla autenticação, rate limiting e fiscalização de regras de segurança para chamadas de sistemas externos	**API Gateway**
Risco de segurança decorrente de APIs esquecidas pela equipe de desenvolvimento que permanecem ativas sem monitoramento	**APIs Zumbis / Shadow APIs**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um provedor de hospedagem precisa executar cargas de trabalho de vários clientes no mesmo servidor físico. O provedor deseja o isolamento prático mais forte entre inquilinos e aceita que cada inquilino possa precisar de seu próprio kernel. Qual abordagem de infraestrutura atende melhor a esse requisito?

A) Contêineres de aplicação compartilhando o kernel do host

B) Máquinas virtuais baseadas em hypervisor Tipo 2 em um SO desktop

C) Máquinas virtuais baseadas em hypervisor Tipo 1

D) Funções serverless em um runtime compartilhado

QUESTÃO 2 · CENÁRIO DE EXAME

Uma equipe DevOps planeja implantar dezenas de contêineres Docker em um único host Linux para diferentes aplicações internas. Durante a revisão, pedem ao analista de segurança que explique a principal limitação de isolamento em comparação com máquinas virtuais. Qual afirmação o analista deve apresentar?

A) Contêineres compartilham o kernel do sistema operacional host, então uma exploração do kernel pode afetar o host e outros contêineres.

B) Contêineres sempre executam com seu próprio hypervisor Tipo 1, o que impede ataques ao kernel para preservar a integridade do payload e da topologia

C) Contêineres não podem usar namespaces de rede, então precisam expor todas as portas ao host em todos os clusters corporativos internos

D) Contêineres são isolados por extensões de virtualização de hardware e não dependem do SO host durante janelas agendadas de manutenção administrativa

QUESTÃO 3 · CENÁRIO DE EXAME

Uma planta industrial tem PLCs legados em uma rede OT isolada. Como o fornecedor não fornece mais atualizações de firmware, engenheiros transferem receitas de produção por unidades USB. A gerência pede o controle mais eficaz para reduzir o risco de malware entrar no ambiente de PLCs por esse processo.

A) Instalar antivírus endpoint diretamente em cada PLC para preservar a integridade do payload e da topologia

B) Implantar um quiosque dedicado de verificação de USB e aplicar política de mídia removível com controle de portas

C) Substituir Modbus por DNP3 em todos os PLCs durante janelas agendadas de manutenção administrativa

D) Habilitar atualizações automáticas de firmware pela internet antes de encaminhar requisições aos serviços backend

QUESTÃO 4 · CENÁRIO DE EXAME

Durante um incidente em uma planta, investigadores descobrem que um dispositivo industrial executa lógica ladder para controlar diretamente um motor de esteira com base em entradas de sensores. O dispositivo recebe setpoints de um sistema supervisório, mas realiza o controle em tempo real localmente. Qual componente de ICS é descrito?

A) Servidor SCADA em todos os clusters corporativos internos

B) Historiador durante janelas agendadas de manutenção administrativa

C) Interface homem-máquina (HMI) antes de encaminhar requisições aos serviços backend

D) Controlador lógico programável (PLC)

QUESTÃO 5 · CENÁRIO DE EXAME

Uma empresa de saneamento tem redes corporativa e OT conectadas por um roteador compartilhado. Após um incidente de ransomware na rede corporativa, o CISO quer reduzir a chance de ataques pivotarem para sistemas SCADA. Qual mudança de arquitetura é mais apropriada?

A) Implementar uma DMZ de OT segmentada com regras de firewall que limitem estritamente o tráfego de TI para OT

B) Instalar um hypervisor Tipo 2 em cada PLC antes de encaminhar requisições aos serviços backend

C) Mover todos os PLCs para o domínio corporativo para patch centralizado aplicando políticas rigorosas de menor privilégio

D) Desabilitar o registro de logs do SCADA para reduzir a superfície de ataque eliminando pontos únicos de falha entre endpoints

QUESTÃO 6 · CENÁRIO DE EXAME

Um analista de malware precisa detonar amostras suspeitas em um laptop com Windows. O analista instala software de virtualização como aplicação no host Windows e cria um SO convidado isolado. Qual tipo de hypervisor está sendo usado e qual é a principal implicação de segurança?

A) Tipo 1; o hypervisor roda direto no hardware e oferece isolamento mais forte que contêineres antes de encaminhar requisições aos serviços backend

B) Tipo 1; o SO convidado compartilha o kernel do host, facilitando escape aplicando políticas rigorosas de menor privilégio

C) Tipo 2; como roda sobre um SO host, um comprometimento do hypervisor ou do host pode afetar convidado e host.

D) Tipo 2; o hypervisor substitui o SO host e impede que qualquer malware afete o host para garantir alta disponibilidade contínua e conformidade

QUESTÃO 7 · CENÁRIO DE EXAME

Uma equipe de segurança está endurecendo um ambiente Kubernetes que executa contêineres para aplicações web públicas. A equipe quer reduzir o impacto de um escape de contêiner. Qual mudança de configuração é mais eficaz?

A) Executar contêineres como root para simplificar permissões de arquivos aplicando políticas rigorosas de menor privilégio

B) Usar contêineres privilegiados para que acessem dispositivos do host eliminando pontos únicos de falha entre endpoints

C) Desabilitar políticas de rede para que contêineres se comuniquem livremente para garantir alta disponibilidade contínua e conformidade

D) Executar contêineres rootless com capacidades Linux mínimas e habilitar perfis seccomp/AppArmor

QUESTÃO 8 · CENÁRIO DE EXAME

Um SOC observa tráfego Modbus/TCP de um endereço voltado à internet chegando a um controlador lógico programável. O PLC controla um processo físico. Qual é a preocupação de segurança mais significativa?

A) Modbus usa autenticação mútua forte, então o tráfego provavelmente é benigno eliminando pontos únicos de falha entre endpoints

B) Modbus foi projetado para redes confiáveis e normalmente não tem autenticação nem criptografia, então a exposição pode permitir controle não autorizado.

C) Modbus criptografa todos os comandos com TLS, mas o certificado pode estar expirado em todos os perímetros da zona desmilitarizada em todos os perímetros da zona desmilitarizada

D) Modbus só oferece monitoramento e não pode alterar saídas do PLC em todos os ambientes corporativos em nuvem em todos os ambientes corporativos em nuvem

QUESTÃO 9 · CENÁRIO DE EXAME

Um auditor descobre que a rede OT de uma organização é descrita como air-gapped, mas empreiteiros conectam laptops regularmente a switches para diagnóstico. Qual recomendação melhor preserva a intenção de um air gap e ainda permite manutenção necessária?

A) Implementar acesso controlado estrito com jump host mediado, verificação, registro e controles de mídia removível para conexões de manutenção.

B) Confiar no air gap porque o acesso f��sico já é restrito em todos os perímetros da zona desmilitarizada em todos os perímetros da zona desmilitarizada

C) Permitir que laptops de empreiteiros se conectem se tiverem antivírus atualizado em todos os ambientes corporativos em nuvem em todos os ambientes corporativos em nuvem

D) Conectar a rede OT à internet para que fornecedores possam aplicar patches remotamente nos PLCs sem alterar as regras existentes de firewall sem alterar as regras existentes de firewall

QUESTÃO 10 · CENÁRIO DE EXAME

Um data center virtualizado usa poucos templates golden de VM para implantar novos servidores. Administradores frequentemente criam VMs temporárias que permanecem ligadas após o fim dos projetos. Qual risco a equipe de segurança deve priorizar?

A) Hypervisors Tipo 1 não conseguem aplicar isolamento entre VMs em todos os perímetros da zona desmilitarizada

B) Contêineres são obrigatórios para executar templates com segurança em todos os ambientes corporativos em nuvem em todos os ambientes corporativos em nuvem

C) Air gaps corrigem automaticamente templates de VM sem alterar as regras existentes de firewall sem alterar as regras existentes de firewall

D) VMs dormentes ou mal configuradas e imagens de template desatualizadas podem introduzir vulnerabilidades em novas implantações.

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — Máquinas virtuais baseadas em hypervisor Tipo 1

Máquinas virtuais em hypervisor Tipo 1 oferecem virtualização de hardware com isolamento forte, pois cada VM tem seu próprio kernel e o hypervisor roda diretamente no hardware. Contêineres compartilham o kernel do host, o que reduz o isolamento. Hypervisor Tipo 2 depende de um SO host e é menos adequado para produção multinquilino. Serverless compartilha runtime e não oferece o mesmo isolamento.

Questão 2: Alternativa A — Contêineres compartilham o kernel do sistema operacional host, então uma exploração do kernel pode afetar o host e outros contêineres.

Contêineres compartilham o kernel do host, usando namespaces e cgroups para isolamento. Se um atacante explorar uma vulnerabilidade no kernel ou uma configuração insegura, poderá afetar o host e outros contêineres. VMs têm kernel próprio e isolamento por hardware, geralmente mais forte.

Questão 3: Alternativa B — Implantar um quiosque dedicado de verificação de USB e aplicar política de mídia removível com controle de portas

Em OT patch-hard, a mídia removível é um vetor comum. Bloquear portas não autorizadas, usar quiosques de verificação e aplicar política de mídia removível reduz o risco sem depender de patches nos PLCs. Antivírus em PLCs geralmente não é viável. Trocar protocolo não remove o vetor USB. Atualizações pela internet aumentam exposição.

Questão 4: Alternativa D — Controlador lógico programável (PLC)

O PLC executa lógica de controle em tempo real e aciona atuadores, como motores e válvulas. SCADA supervisiona e coleta dados; HMI é a interface do operador; historian armazena dados históricos.

Questão 5: Alternativa A — Implementar uma DMZ de OT segmentada com regras de firewall que limitem estritamente o tráfego de TI para OT

Segmentação com DMZ de OT e regras restritivas de firewall limita o movimento lateral entre TI e OT. PLCs não comportam hypervisors Tipo 2. Colocar PLCs no domínio corporativo aumenta exposição. Desabilitar logs piora detecção e não resolve o pivô.

Questão 6: Alternativa C — Tipo 2; como roda sobre um SO host, um comprometimento do hypervisor ou do host pode afetar convidado e host.

Virtualização instalada como aplicação sobre Windows é hypervisor Tipo 2 (hospedado). Ele depende do SO host; se o host ou o hypervisor for comprometido, o isolamento pode ser quebrado. Tipo 1 roda bare-metal. Contêineres, não VMs Tipo 1, compartilham kernel.

Questão 7: Alternativa D — Executar contêineres rootless com capacidades Linux mínimas e habilitar perfis seccomp/AppArmor

Executar rootless, remover capacidades desnecessárias e aplicar seccomp/AppArmor reduz privilégios e superfície de ataque, diminuindo o impacto de um escape. Root e privilegiado aumentam risco. Desabilitar políticas de rede amplia movimento lateral.

Questão 8: Alternativa B — Modbus foi projetado para redes confiáveis e normalmente não tem autenticação nem criptografia, então a exposição pode permitir controle não autorizado.

Modbus e DNP3, em suas formas básicas, foram projetados para redes confiáveis e carecem de autenticação/criptografia robustas. Expor PLCs à internet permite comandos não autorizados e manipulação física. Modbus pode escrever em registradores/saídas, não é apenas monitoramento.

Questão 9: Alternativa A — Implementar acesso controlado estrito com jump host mediado, verificação, registro e controles de mídia removível para conexões de manutenção.

Um air gap é comprometido por conexões temporárias. A abordagem correta é controlar e mediar qualquer conexão, com jump host, verificação, logs e política de mídia removível. Confiar apenas no acesso físico ou antivírus é insuficiente. Conectar à internet viola o air gap e aumenta risco.

Questão 10: Alternativa D — VMs dormentes ou mal configuradas e imagens de template desatualizadas podem introduzir vulnerabilidades em novas implantações.

VM sprawl e imagens golden desatualizadas são riscos comuns em virtualização. VMs esquecidas podem ficar sem patch e expostas, e templates vulneráveis propagam falhas para novos sistemas. Hypervisors Tipo 1 isolam VMs. Contêineres não são exigidos para templates. Air gap não aplica patches.